GRC Review of Nexus Financial Services

Summary

Nexus is a growing financial services company with about $800 million in assets. It has grown quickly, but decisions are still made informally and there is no formal GRC framework. This report explains what GRC means, lists three problems at Nexus, and recommends one action to start fixing them.

1. What Governance, Risk, and Compliance Mean

Governance is how a company is directed and controlled. It sets the rules, says who is responsible, and makes sure people follow them. Think of it as the steering wheel.
Risk management is spotting what could go wrong before it happens, judging how serious it could be, and deciding what to do about it. Think of it as checking the road ahead.
Compliance is following the laws, regulations, and company policies that apply to the business. Think of it as obeying the traffic laws.
Together, GRC means a company has clear direction, knows its dangers, and stays within the rules.

2. Three Issues and Their GRC Category

Issue	What is wrong	Why it matters	GRC category
1. No clear process to approve or enforce policies	Policies are not formally approved, and nobody checks that staff follow them.	People work in different ways, and leadership cannot show that policies are followed.	**Governance**
2. No standard way to assess risk before business decisions	Decisions are made without first asking what could go wrong.	Problems show up only after they happen, causing financial loss or damage to reputation.	**Risk Management**
3. No one is responsible for tracking regulations and deadlines	Nobody watches for regulatory requirements or their due dates.	Nexus could miss a deadline and face fines, penalties, or loss of customer trust.	**Compliance**

Why this matters: in 2023, Meta Ireland was fined 1.2 billion euros. The case showed weak governance, risks that were not escalated, and a breach of data privacy rules, all in one failure. The gaps at Nexus are the same kind of weakness, just at an earlier stage.

3. One Recommendation

Set up a simple GRC framework, led by a named GRC coordinator who reports to senior leadership and the Board.
The framework uses three simple lists, each with a named owner and regular review dates:

- **Policy list:** every policy, who approves it, its version, and when it is next reviewed.
- **Risk list:** each risk, how likely and how serious it is, who owns it, and what is being done about it.
- **Compliance list:** each regulatory requirement, who is responsible, and its deadline.
- **Monthly review** with leadership, so problems are raised early.

Why this one action: it fixes all three issues together. Governance gets an owner, risk gets a routine, and compliance gets someone watching the deadlines. It is low cost and can start quickly, which suits a growing company.

A 90-day starting plan

Period	What happens
First 30 days	Appoint the coordinator and owners. List existing policies, key business risks, and known regulatory requirements.
Days 31 to 60	Create the three lists, agree a simple way to score risks, and set review dates.
Days 61 to 90	Review the biggest risks and any overdue requirements with leadership, and track the fixes.

Conclusion

Nexus does not need a big overhaul to begin. It needs clear ownership, a simple way to check risks, and someone tracking the rules. Starting there will protect the company, build trust with regulators and customers, and support its growth.

This review is based only on the case study scenario. It does not say Nexus has broken any law. The company should confirm which regulatory requirements apply to it.